

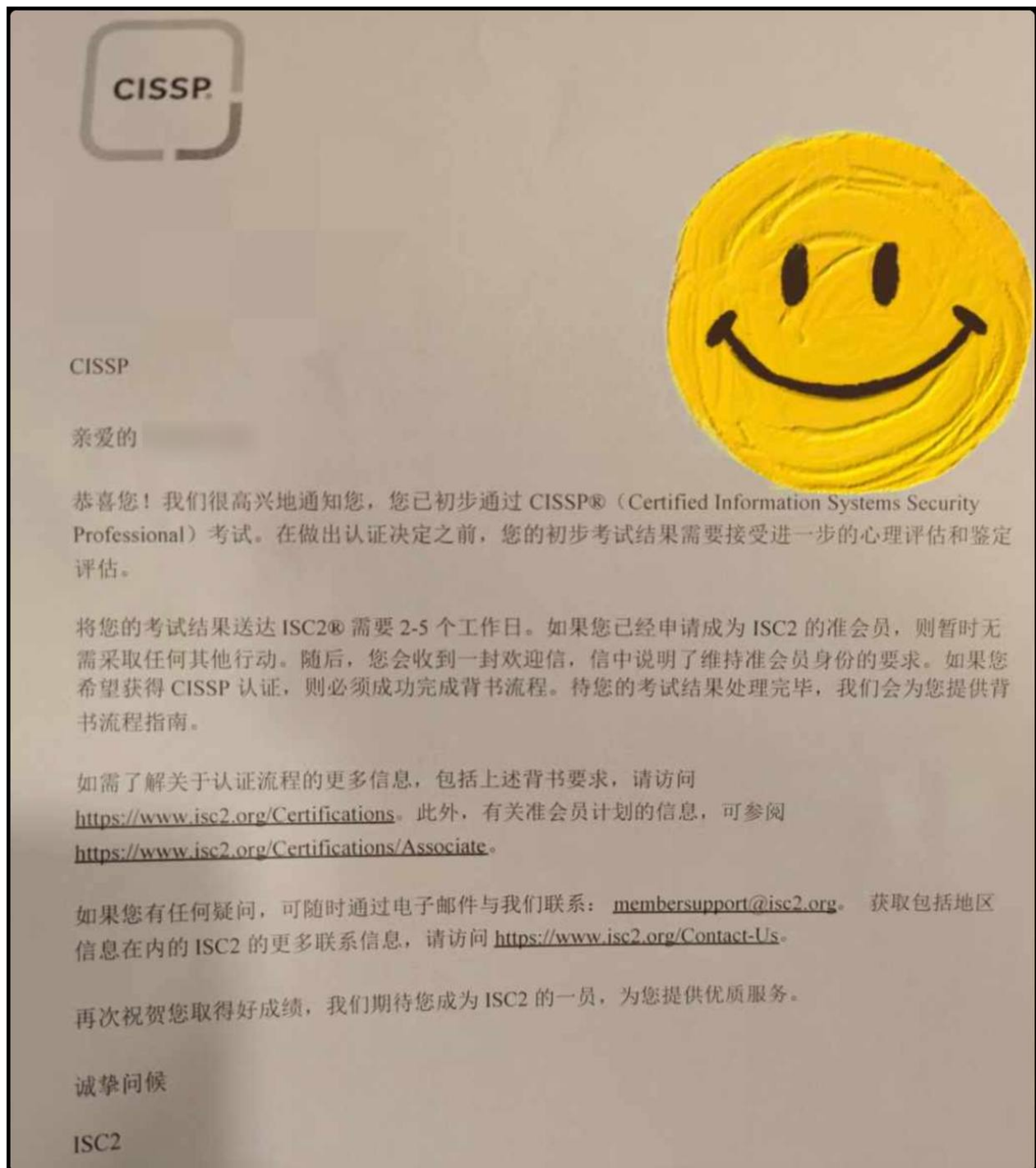
Passing the CISSP Exam in 60 Days: My Experience

By J0o1ey · Translated from the Chinese original

Preface

A few months ago I passed the CISSP exam, ending two full months of torment.

Here's my experience, for whoever comes after me.



1. Registration (a.k.a. the Discouragement Guide)

First, my background: nine years in security, currently doing application security (SDLC direction) at an internet company.

My advice: register only if you have real security work experience AND decent English.

If you have zero industry experience, I genuinely advise against it — you'll most likely be paying money to suffer!

1.1 Why Experience Matters

Under the old linear exam format, everyone sat roughly the same questions, so a certain amount of corner-cutting could get you through.

But in 2023, (ISC)² recognized this, invalidated a large batch of results and forced retakes, and switched the exam to CAT mode (think computer-adaptive questioning: whatever knowledge area you answer poorly, that's the area it keeps hammering you on). Everyone now gets a different exam — "corner-cutting" is essentially dead.

Most questions aren't knowledge you learned from a book; answering them takes fairly rich practical experience and an understanding of security management. Finishing the textbook is NOT the finish line. When the exam starts, everyone stares at the screen dazed, because what you studied and what you're tested on barely overlap.

1.2 Why Your English Shouldn't Be Too Weak

The Chinese translations in the CISSP exam are often a hot mess — awkward, and unlike any normal technical phrasing. You need the ability to read the original English questions.

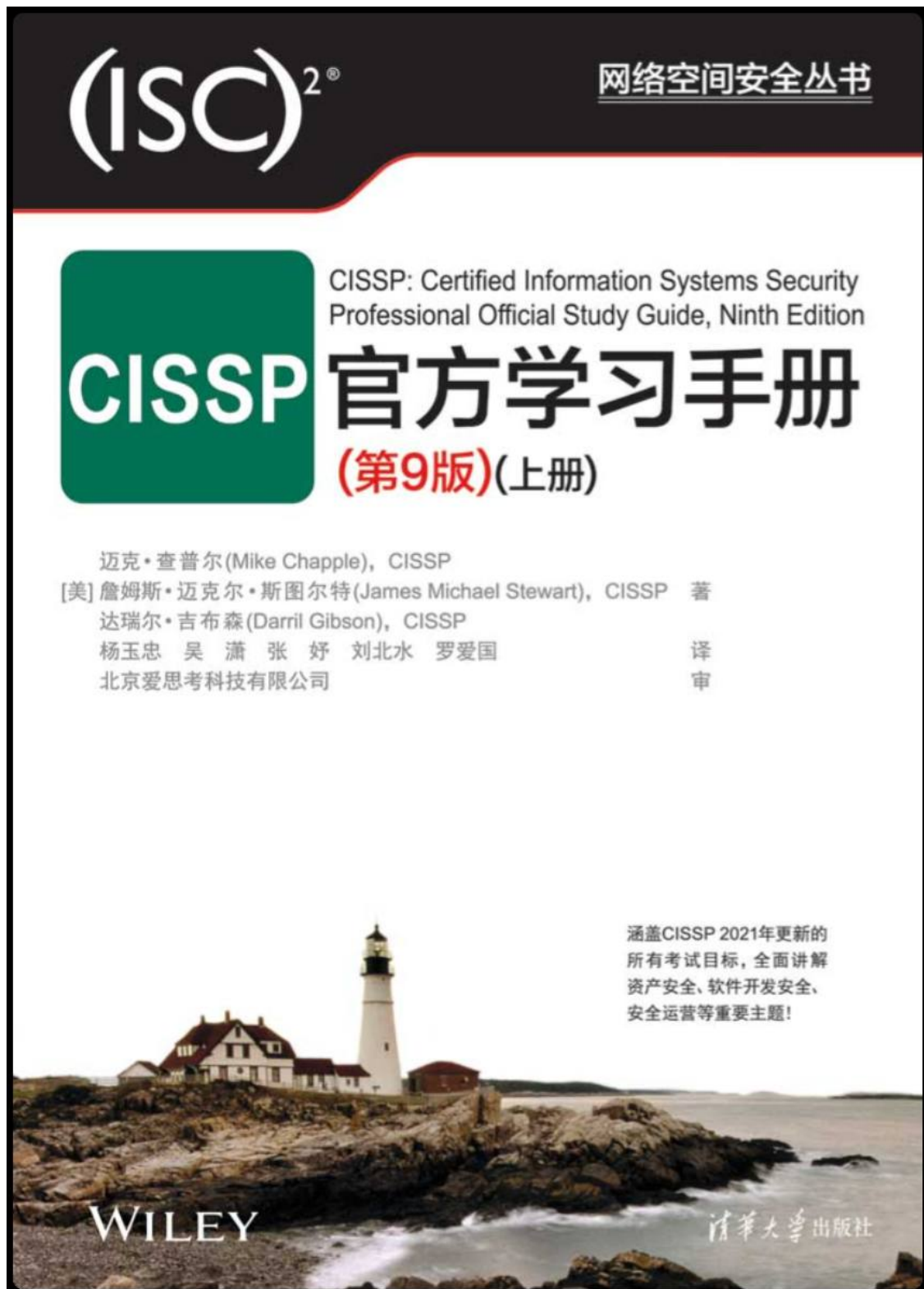
For brothers with a weaker English foundation, that's a real hurdle.

2. Learning the Fundamentals

CISSP content spans 8 domains, covering basically everything from technology to management — a kilometer wide and a foot deep. Nothing goes terribly deep, but it's highly comprehensive, aimed at cultivating security-management thinking.

For fundamentals, the official textbook is the OSG (CISSP Official Study Guide).

The community alternative is the AIO (CISSP All-in-One). Pick one; no need for both.



I recommend the OSG as your main text — it's effectively the official syllabus. The OSG is now in its 10th edition, but the Chinese market only has the 9th; the exam already covers 10th-edition content. If your English is decent, go straight for the 10th; the 9th can be found on Taobao.

PS: one complaint — the Chinese OSG contains numerous translation errors and awkward renderings. While studying, memorize the key terms in English.

For example, "rogue tower" was translated in the Chinese OSG as "hooligan tower" (流氓塔), which confused me for ages... before I realized it just meant a fake base station.

For the OSG, I recommend at least one careful, complete read-through — unless you already have extremely rich enterprise security-management experience.

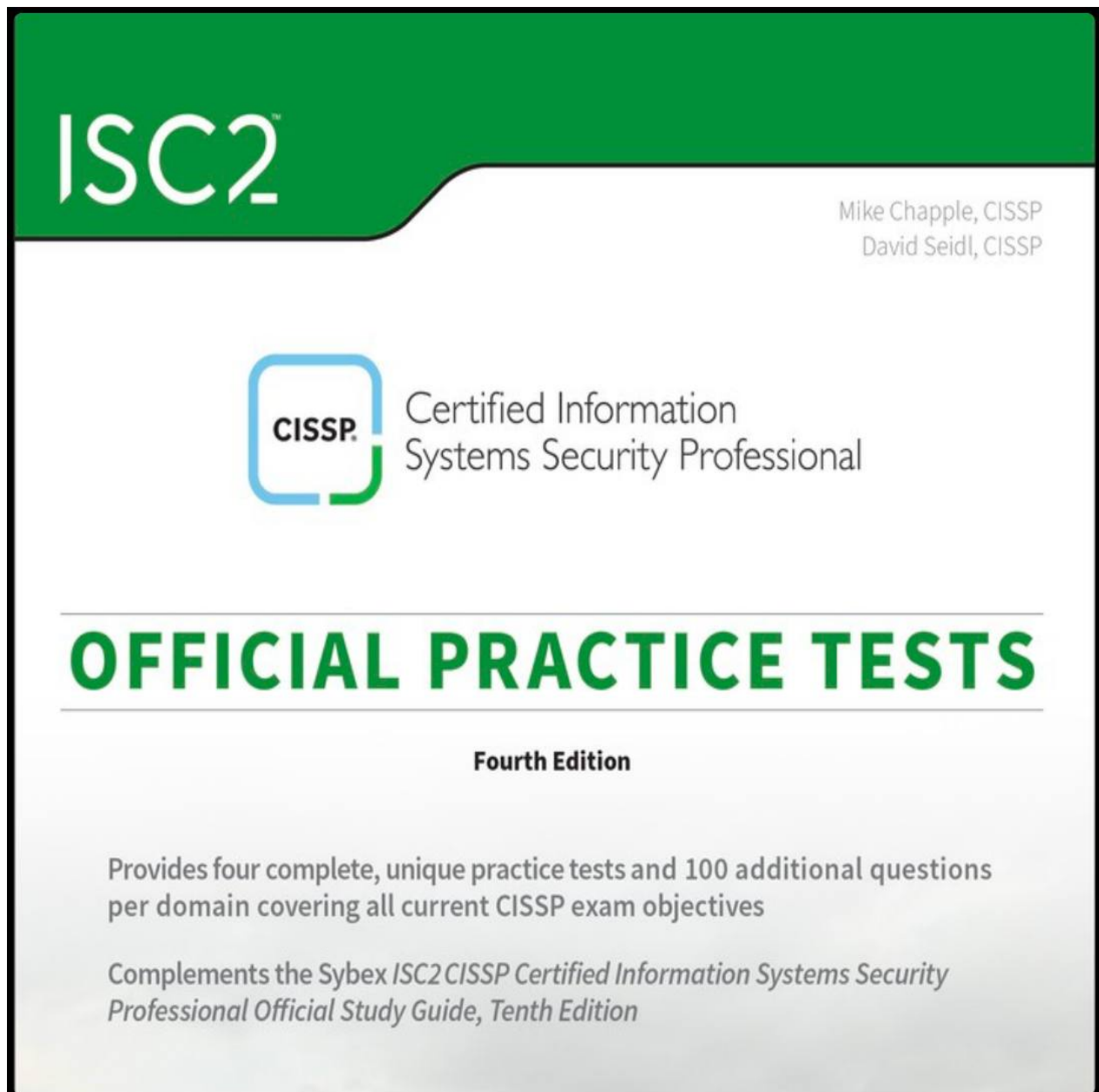
Plenty of people claim you can skip the book; I find that unscientific. The knowledge points may be scattered, but the book genuinely helps your structured thinking.

3. Practice Questions

Core principle: do lots of practice questions, but NEVER memorize them. Do not bring the logic of domestic certification exams to CISSP.

For practice, use CISSP Official Practice Tests / Official Exam. The books are in English; translated versions circulate online (many translations are inaccurate).

I finished every question in Official Practice — all eight knowledge domains plus the four comprehensive practice sets — and mastered the knowledge behind every option in every question.



Random-drawing from the eight domain question banks, my accuracy was above 90% before the exam.

The four comprehensive sets, done as mock exams, came in at 75%-85%. Use that as a reference.

Also: strongly recommend an error notebook. Review it from time to time. Understand the knowledge — don't memorize options.

4. Payment and Scheduling

CISSP can be booked in advance on the (ISC)2 website; exams run in the last month of each quarter. Testing is outsourced to Pearson VUE.

The fee is currently US\$750 per attempt. Fail, and the money evaporates — you simply pay again. (So prepare properly before sitting it; otherwise you're literally donating. \$750 was a

month of meals for me.)

Sometimes the official "peace-of-mind" bundle is offered: \$950 for one attempt plus a free retake next quarter if you fail.

If you're not confident, the insurance is worth it for peace of mind (I bought it, never needed it — passed first try).

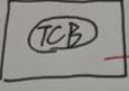
5. Pre-Exam Preparation

Bring your national ID plus a credit card with your signature on it (the official requirement says credit card) — you'll need it before entering the exam room.

Knowledge-wise, definitely build your error notebook; work through every knowledge point against the OSG or GPT until you truly understand it — it might just appear on the exam.

Handwritten notes are personal preference. I like writing things down and reviewing periodically; before the exam I filled dozens of pages like the one below (ignore my ugly handwriting).

119. SAML使用断言传递身份信息^①和授权信息^②
 (多) OIDC (OpenId + OAuth) 使用JWT传递身份验证和授权
 SPML (服务配置标记语言)
 基于XML, 专门为交换用户信息而设计
 用于同步创建、修改、删除账户 XACML (可扩展访问控制标记语言)
 在XML中定义访问控制策略用于实现RBAC

120. TCB (可信计算基) 硬件、软件和控制结合体
 → 安全边界 - 把TCB与系统

 → 参考监视器(验证对每个资源的访问权限)
 (请求主体的凭证是否符合客体要求)

TPM (Trusted Platform Module) 可信平台模块
 主板上密码处理器芯片的规范 - 存储设备被拨不能写

HSM (硬件安全模块)
 用于管理/存储数字加密密钥
 支持速度更快的数字签名以及改进身份认证

121. SLA 包含哪些内容?
 ① 产品和服务满足性能要求
 ② 服务能持续运行的时间 (例98%)
 ③ 处罚条款
 还包括请解备忘录(MOU) 或互连安全协议(LSA), 不涉及处罚

122. CRM 客户关系系统
 ITSM (IT 服务管理)
 → 管理IT服务的整个生命周期
 进行变更管理选ITSM

123. DRP 中关于 incident report 应该包含什么?
 主要负责人的联系方式

124. 安全意识培训计划中, 最重要的是
 教育

125. VLAN 与广播域 -- 对应

126. 战争拨号 - 控制PBX以扫描其他电话网络
 控制PBX (使用分组交换网)

6. Before the Exam Starts

On exam day, head to the official Pearson VUE test center — first-tier cities (Beijing, Shanghai, Shenzhen, Chengdu, Xi'an, etc.) all have them.

If your city has no test center, book a hotel and travel — it's rather exhausting.

Most sessions start in the morning and run on time. Once inside the test-center area, no study materials allowed and phones off.

Staff then verify identity, take your photo, and — before you formally enter — scan your palm vein pattern (yes, you read that right: palm, not fingerprint).

The outside of the Beijing Pearson VUE test center looks roughly like this:



7. During the Exam

A dozen or so people share one room, with cameras and microphones overhead the whole time, and tall partitions between seats.

The people next to you probably aren't even taking the CISSP — Pearson VUE hosts many exams.

So don't harbor any funny ideas; the room is stricter than the gaokao.

The current CAT exam is "adaptive": three hours, all single-choice, and you may answer anywhere from 100 to 150 questions. The computer continuously computes your accuracy and pass probability. After question 100, if the computer decides you've passed, the exam simply ends. (Of course, it may also decide you're definitely failing.)

My exam ended at question 120 — about one minute per question.

So keep your mindset steady: regardless of which question you're on, calm thinking plus mobilizing your experience and knowledge is what matters most.

As for the difficulty everyone asks about, let me just say: quite hard — and I say that believing my security experience exceeds most people's.

Only about 25% of the questions can be instantly killed with book knowledge; the rest require choosing the best answer from the scenario, which is genuinely agonizing.

When the exam ended, my whole brain felt numb.

8. After the Exam

Somewhere within the 100-150 question range, the machine mathematically decides whether you pass. You never know whether clicking "Next" will drop the four big words "Exam Ended" on you. Afterwards, you re-scan your palm and verify identity;

then the proctor hands you your score report face-down (reportedly so that friends who failed together are spared the embarrassment).

If the report matches the first picture in this article — congratulations, you've passed the CISSP exam!

If it lists the domains where you fell short — my condolences; the battle continues.

9. Endorsement and Maintaining the Certificate

After passing, (ISC)2 emails you; once it arrives, prepare your endorsement.

Dear [REDACTED]

Congratulations! We are pleased to inform you that you have passed* the CISSP examination. By passing this examination, you have completed the first of three steps toward earning your certification and becoming an ISC2 member!

Next, please complete the [online application](#) form and verify you have read, understand and attest to fully support the ISC2 Code of Ethics. This step must be completed even if you already hold another ISC2 certification. *You must submit your application within nine months of your exam date.*

Endorsement to full "member" status requires five years of work experience. You can either have an existing member endorse you, or submit to official experience review.

Most people choose a member endorser — such services exist on Taobao. An IT-related bachelor's degree waives one year.

The "associate" tier requires no work experience: \$50/year to maintain, and you convert to full member after meeting the experience requirement.

After the endorsement review passes (roughly 6-8 weeks), you'll be notified by email; pay the annual maintenance fee (\$135) and the CISSP certificate is yours.

The paper certificate later ships to ISC2's China office, which then contacts you to confirm the delivery address.

Dear _____,

Congratulations! Your certification application for CISSP has been approved. You're now just one step away from gaining your certification and becoming an ISC2 member with all the [benefits](#) it brings.

Last Step

As the final step in the certification process, please log in to your [member dashboard](#) and pay your Annual Maintenance Fee (AMF) if applicable (see below).

Important:

- If you currently hold an ISC2 certification other than CC, you are not required to pay an additional AMF
- If you hold the CC or are an Associate of ISC2, you are only required to pay the difference between your current AMF and the CISSP full-membership AMF. After this payment, you will only be obligated to pay a single full-membership AMF per year that will cover all your ISC2 certifications/designations.

And that's what the certificate looks like~

 International Information System Security Certification Consortium	
The ISC2 Board of Directors hereby awards	
Name	
the credential of	
Certified Information Systems Security Professional	
Having met all of the certification requirements, adoption of the ISC2 Code of Ethics, and successful performance on the required competency examination, subject to recertification every three years, this individual is entitled to all of the rights and privileges associated with this designation, as defined in the ISC2 Bylaws.	
 Dan Houser - Chairperson	
 Laurie-Anne Bourdain - Secretary	cert Num Certification Number
	Certification Cycle Certified Since: 2024

After receiving it, you pay the annual fee (\$135) and earn CPE credits to maintain it — 120 CPEs per 3-year cycle.

All the details arrive with the certificate.

10. Finally

Everyone chases the CISSP for its unusual gold content — which is why, like me, you're choosing to pay money to suffer.

Wishing you "everything you studied appears on the exam" would be unrealistic; so instead, my sincere wish: may every guess you make in the CISSP exam be the right one.

Contact Me

For questions about CISSP registration or study, reach me on WeChat: J0o1ey997

